

Pharming is a cyberattack intended to redirect a website's traffic to another, fake site by installing a malicious program on the victim's computer in order to gain access to it

T5 - Example of pharming attack to HTTP and HTTPS

WARNING: setting up a fake website and implementing a pharming attack is an **offensive procedure**. Be aware of what you are doing and carefully consider the possible consequences. The operations reported in this document must be only considered in terms of **educational activity** and for **defensive operations**.

Goal of this tutorial

redirecting a browser-generated request to a website that is not the intended destination of the request (this is a fake site: it differs slightly from the original website)

The goal of this tutorial is to present a **pharming attack** that is initially directed to a website that is accessible by using the **HTTP** protocol. In the following, a more complex attack on **HTTPS** is also considered.

How it is possible: routing of packets isn't protected by encryption (possible to redirect the communication)

Attacking HTTP

The general structure of the attack is quite simple and it is composed of the following steps:

1. **cloning** of the pages of the target website + implementing **local modifications**;
2. setup of a **"fake" HTTP server** that is used to service the pages requested by the victim web browser;
3. **redirection of the requests** made by the web browser to the "fake" HTTP server.

Actions **1)** and **2)** are fairly straightforward and they require only minimal system administration knowledge such as the cloning of a website (e.g., using "wget" or a similar software tool) and installing + setting up a local web server (e.g., "apache" or "nginx"). The core of the attack is therefore about point **3)**, that implements the redirection of the communication between the browser (or the whole victim computer) and the server. **This redirection can be implemented in many different ways**. For example, it would be a different procedure if the attacker is willing to redirect only the traffic from the specific computer used by the victim or if he/she plans a more large-scale attack on a whole network.



(An attack on an entire local network, not just a single computer)

In the case of a network-wide operation, the typical attack pattern is about modifying the DNS host addresses provided by the router (usually through the **DHCP protocol**) to the hosts in the local network. In fact, the DHCP protocol is not only responsible for providing an IP address to

Unlike a standard proxy (which requires the user to manually configure their browser to use it), a transparent proxy intercepts connections at the network level without the user or browser needing to make any special configuration changes or install any specific software. The victim's web traffic is silently redirected through this proxy, which is controlled by the attacker, who can choose to display a fake page instead of the real one.

iptables and nftables are administration tools built into the Linux operating system kernel. They allow you to define very strict rules for how to handle incoming and outgoing network packets. The attacker sets up a "Network Address Translation" rule. When the victim's operating system generates a packet destined for the legitimate bank's IP address, the kernel rule intercepts the packet on the fly and replaces the destination IP address with that of the fake server.

every host that is newly connected to the network ^{but also 2} as well as for providing some basic communication parameters such as the IP addresses of the **DNS servers** and the IP address of the default gateway to be used in the local area network. More specifically, it is worth noticing that also by modifying the IP address of the default gateway, it would be possible to divert the communication to a fake HTTP server. A somewhat more complex procedure would consist of the installation (by the attacker) of a ^{unauthorized} ~~rogue~~ DHCP server that provides forged ^(falsified) parameters to the clients entering the network. This would be typically combined with a Denial-of-Service (DoS) attack to the legitimate DHCP server to slow it down or to fully stop its execution (see the details about the inner workings of [DHCP](#)).

③ If the attack is limited to a single host then a simple, very effective but quite visible solution is to modify the content of the "/etc/hosts" file that is used by the local DNS resolver for providing a very quick resolution for some local hostnames to specific IP addresses. When this approach is followed for mapping hostnames to IP addresses, then the whole mechanism works locally without requiring to query a proper external DNS server. Other more complex possibilities are about the configuration of (transparent) HTTP proxies or through the modification of some specific information (e.g., the destination IP address) on the packets in the communication flow. This "translation" operation can be accomplished by specific tools that operate at the kernel level such as "iptables" and "nftables". Their activity is very hard to stop ^(Attacking advantage) (i.e., system integrity) but they require root (i.e., administrator) permissions to be executed ^(Attacking limitation).

Attacking HTTPS

Il TLS ha tre obiettivi fondamentali per proteggere i tuoi dati: Confidentiality: I dati sono cifrati; nessuno può intercettarli e leggerli in chiaro lungo il percorso. Integrity: I dati non possono essere alterati durante il viaggio senza che il sistema se ne accorga. Authenticity: Garantisce che tu sia veramente connesso al server legittimo e non ad un impostore. Se l'attaccante usa le tecniche precedenti su un sito HTTPS, il browser della vittima verrà sì reindirizzato sul server fake, ma si accorgerà immediatamente che il server fake non possiede il certificato digitale valido per quel dominio.

The main difference between HTTP and HTTPS is the usage of an encrypted communication protocol based on [Transport Layer Security](#) (TLS). The goal of TLS is to provide confidentiality, integrity, and also authenticity to the data stream. In this tutorial, it is assumed that the reader has a general knowledge of the HTTPS protocol and the related basic encryption functionalities as described in the slides. If you are interested in more detailed knowledge of the topic then I suggest reading the specific sections in the course textbook (that are Section 22.3 "Secure Sockets Layer (SSL) and Transport Layer Security (TLS)" and Section 22.4 "HTTPS").

When the phishing attack involves the HTTPS protocol, the three steps that have been described above are not sufficient. In fact, it is also necessary to assume the **compromission of the SSL/TLS certificate in the browser**. Since it is possible, but very unlikely, that an attacker is able to compromise a certificate authority then in the following we will assume that the compromission will be only local to the attacked system (i.e., the device of the victim). In fact, if the private key used by the certificate authority (to sign the issued certificates) has not been compromised then it would be impossible for the attacker to forge a fake certificate that is suitable to be used by the fake website without triggering a warning from the browser (e.g., the broken padlock in some browser bars). This means that the best possibility for the attacker is to attack the integrity of the web browser used by the victim. Also in this case, there are many possible ^{methods} ~~avenues~~ of attack but the simplest consists of adding a new host certificate (or the certificate of a certificate authority) to the list of trusted certificates recognized by the browser. It

The document states that this operation does not require root or administrator privileges and does not modify the browser's code (the binary file remains unchanged); it is merely a change to the browser settings.

Once this is done, the attacker has the certificate for their clone website signed by their own fake CA. When the victim visits the pharming site, the compromised browser will verify the signature, see that it belongs to the fake CA (which is now considered trusted), and load the fake site without displaying any warnings or a broken padlock.

is worth noticing that this operation is very simple, it does not affect the integrity of the browser binary file and it requires only a configuration modification of the specific browser that can be made by the final user without any special execution privilege. More specifically, if a new fake certificate authority is added to the browser then all the certificates signed by the fake authority will be recognized as valid by the compromised browser without triggering any warning.

Revocation of Certificates

What happens when security isn't compromised on the victim's computer, but when an official Certificate Authority (CA) is compromised?

A final point that must be considered is the compromission of the certificate authority. Fortunately, it does not happen very often but it is still an event that must be considered and properly handled. When it happens, all the certificates that have been issued by the authority with the compromised private key must be revoked as soon as possible. In other words, it is necessary to implement a mechanism for the certificate revocation. This mechanism should be implemented in all browsers and libraries that make use of encrypted communications based on TLS. This point is very important but it is not very clear to some developers. Moreover, in the past, we have already seen many [problems](#) and [issues](#) with certificate validation and revocation.

Quando una chiave privata viene compromessa, non si può semplicemente aspettare che i certificati scadano da soli (la scadenza può richiedere mesi o anni). Tutti i certificati emessi con quella chiave devono essere annullati immediatamente, cioè revocati. Per fare questo, i browser e le librerie software che usano TLS/SSL devono implementare dei meccanismi di controllo per verificare in tempo reale se un certificato è ancora valido o se è stato revocato.

I due standard principali utilizzati nel web per gestire questa smentita sono:

- Certificate Revocation List: La CA pubblica una blacklist di tutti i certificati revocati. Ogni volta che il browser visita un sito, scarica questa lista e controlla che il certificato del sito non sia presente nell'elenco. Ogni volta che il browser visita un sito, scarica questa lista e controlla che il certificato del sito non sia presente nell'elenco.
- Online Certificate Status Protocol: Invece di scaricare un'intera lista (che può diventare enorme), il browser fa una domanda rapida e diretta al server della CA: "Questo specifico certificato è ancora valido?" e riceve una risposta immediata (Sì/No).